

The enterprise GenAI stack, October 2026

What changed since the popular stack diagram, what a regulated asset manager should select, and what to deliberately not build yet

Reference architecture review · 9 layers · 8 enterprise controls · 140 products · Personal research

The answer in one sentence

Build a firm-owned control and evidence plane first. Run regulated work as deterministic workflows with one bounded model step and a human approval gate. Consume models as a two-vendor portfolio. Treat every product beneath the plane as replaceable.

Control first

Gateway, identity, privacy, configuration, evaluation and one evidence store are the firm's own. They make exit a configuration change.

Workflows, not free agents

Every serious framework now separates deterministic workflows from agent loops. Regulated work defaults to the workflow.

Products are components

Ownership of 'neutral' tools changed hands repeatedly in 2025–26. Independence and exit must be designed in, not assumed.

What we reviewed, and how much had moved

80

tiles in the original graphic

39

of 80 tiles out of date: acquired, renamed, mislabelled or unverifiable

140

products profiled (80 tiles, 48 controls, 12 additions)

1,255

sources logged with URL and access date

How the work was done

- Eight parallel research streams, primary sources first; two adversarial verifiers re-checked 192 high-risk claims (no fabrications found).
- Seventeen chapters on a 13-part template, each product scored 1–5 on eight criteria with generic and regulated-FS weights.
- Reader checkpoints decided the scoring rules and the contested tiers; every claim is labelled verified, reported, judgement or recommendation.

Ten findings that change the picture

- 1 Catalogue → control system**
None of the eight enterprise controls appears in the graphic.
- 2 Neutral tools were bought**
Arize, Langfuse, Promptfoo, Portkey, Lakera, Voyage, Jina and others changed hands.
- 3 Models are tiered families**
Gated top tiers and short lives: model choice is a lifecycle discipline.
- 4 Workflows vs agents**
Every serious framework now ships both; this is the key design choice.
- 5 Protocols under foundations**
MCP and A2A now sit in a Linux Foundation project; agent identity is a product category.
- 6 Vector DB is a feature**
Hybrid search ships in most stores; retrieval is a governed index.
- 7 Memory layer is thinning**
Open editions narrowed; hyperscalers ship memory in their runtimes.
- 8 Supply chain is attack surface**
A gateway package was compromised; a tool broker leaked tokens.
- 9 Regulatory anchors moved**
SR 26-2 excludes GenAI; EU high-risk duties now 2 Dec 2027.
- 10 'Open source' often is not**
Source-available, AGPL, non-commercial and threshold licences.

Independence can no longer be assumed from a product's origins

Product (layer)	New owner	Status (as of 8 October 2026)
Arize Phoenix and AX (evaluation)	Dynatrace	Completed 1 October 2026
Langfuse (evaluation)	ClickHouse	Announced 16 January 2026
Promptfoo (red-teaming)	OpenAI	Announced 9 March 2026; closing not published
Voyage AI (embeddings)	MongoDB	Closed February 2025
Jina AI (embeddings)	Elastic	Completed 9 October 2025
Tavily (search API)	Nebius	Closed 19 February 2026
OpenRouter (model router)	Stripe	Agreed 19 August 2026; pending
Portkey (gateway), Protect AI (security)	Palo Alto Networks	Completed 2025–26
Lakera (guardrails)	Check Point	Completed 22 October 2025
Guardrails AI; Helicone	Harvey; Mintlify	Completed; Helicone in maintenance mode

What it means

A model vendor now owns a red-team tool; security vendors own gateways. Effective challenge and exit planning have to be designed, not inherited.

What we do about it

Keep evaluation datasets, routes and policies in Git; keep two red-team tools, one independent of the model vendor; re-run due diligence on every change of control.

The regulatory anchors moved in 2026

17 Apr 2026



SR 26-2 replaces SR 11-7

Generative and agentic AI are out of scope: firms must write their own GenAI standard

2 Aug 2026



EU AI Act GPAI enforcement

Commission powers over general-purpose model providers start

18 Mar 2027



PRA PS7/26 · FCA PS26/2

Material third-party notifications and registers begin

2 Dec 2027



EU AI Act Annex III

High-risk duties deferred by Regulation (EU) 2026/1744

Concentration sits with the clouds, not the model vendors

DORA's first critical-provider list and the UK CTP designations name hyperscalers and no model vendor. PRA SS1/23 and the EU AI Act are now the operative model-risk anchors.

The architecture

Eight hypotheses tested; nine layers renamed, split or merged; one control plane added

Four planes under one firm-owned control plane

CONTROL PLANE (firm-owned)

C1 AI traffic gateway · C2 guardrails · C3 privacy service · C4 identity · C5 configuration of record · C6 FinOps · C7 AI security · C8 governance and evidence store

EVALUATION AND OBSERVABILITY PLANE (L9)

Firm OpenTelemetry collector · platform of record · CI and online evaluations · two red-team tools

AGENT PLANE (L3, L4)

Workflows by default · bounded agent steps · durable execution · tools behind a governance sub-layer

KNOWLEDGE PLANE (L8, L7, L6 + L5)

Ingestion envelope · retrieval optimisation (embed + rerank) · derived, entitlement-filtered stores · memory service last

MODEL PLANE (L2, L1)

In-region model access · vLLM exit route · two-vendor portfolio + small + open-weight

How to read it

The control plane governs every call and holds the evidence. Planes beneath it are built from replaceable products.

Layer numbers are kept for traceability; names changed where the evidence required it.

Hypothesis verdicts: what the evidence did to the nine layers

#	Hypothesis	Verdict
H1	Split inference; promote the gateway	Split L2 into access, serving, optimisation; gateway becomes C1 (model, tool and agent traffic)
H2	Agent framework is not one layer	Split: deterministic workflows (default), bounded agent steps, durable execution
H3	Identity and tool governance	Keep: a tool-governance sub-layer in L4; C4 and C7 make the decisions
H4	Memory vs retrieval	Merge into the stores layer as a governed memory service; build it last
H5	Rename vector databases	Rename L6 'Retrieval, knowledge and memory stores'
H6	Embeddings + reranking	Merge into L7 'Retrieval optimisation'
H7	Ingestion needs lineage, DLP, ACLs	Keep, widened: a built ingestion envelope around replaceable parsers
H8	Evaluation is cross-cutting	Reposition L9 as an evidence plane; one evidence store with C8

Twelve decisions that define the architecture

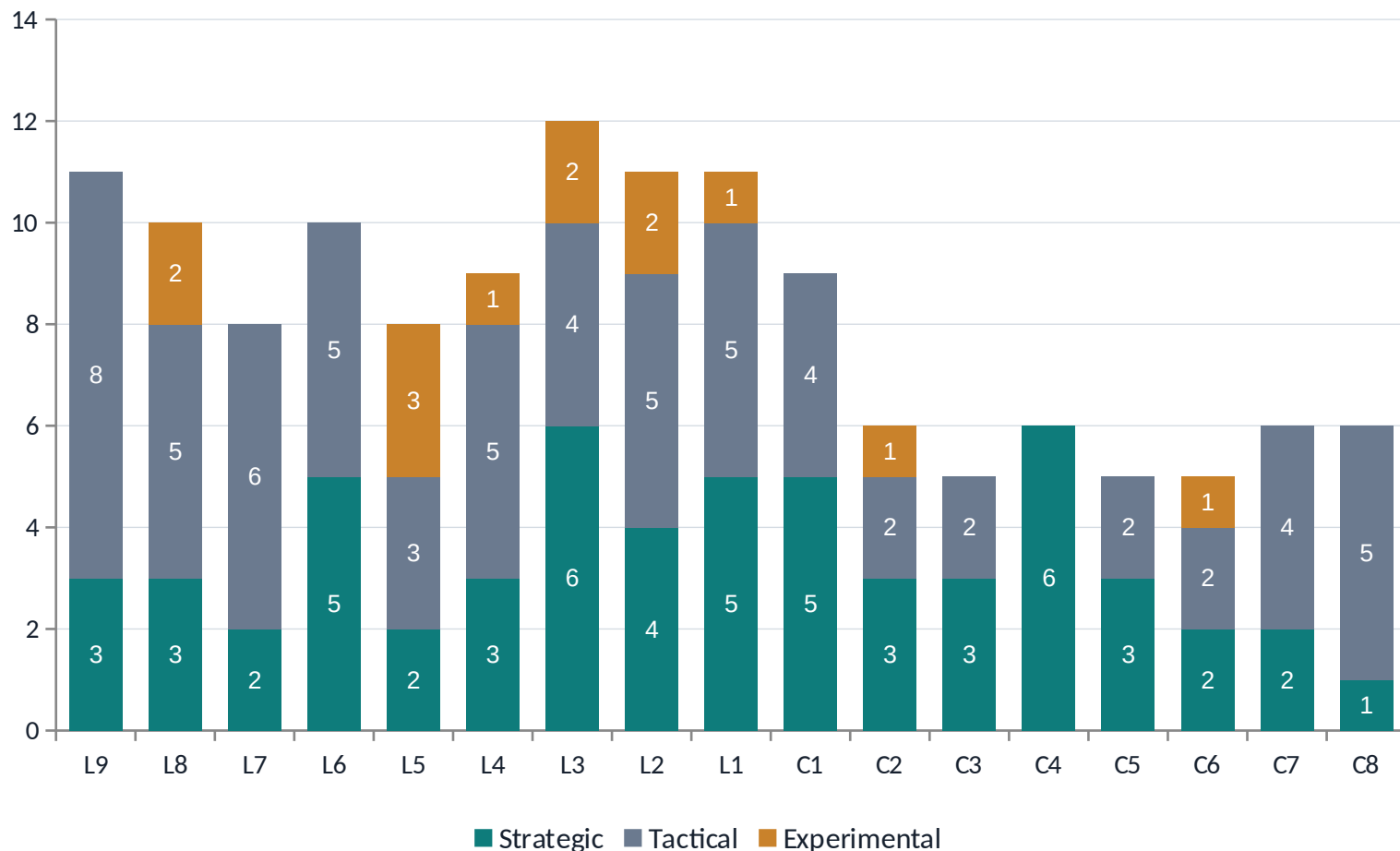
- 1 One gateway of record for all model, MCP and agent traffic; two deployments, in region, failing closed
- 2 Evaluation and observability from day one; datasets in Git; two red-team tools
- 3 A firm-owned, immutable evidence store keyed by trace ID
- 4 A two-vendor model portfolio in region, plus a small model and a self-hosted exit route
- 5 Deterministic workflows by default, with approval gates only a named human can resume
- 6 Read-only tools for authoritative data, behind a governed tool gateway
- 7 Every agent a registered identity acting on behalf of a human, deny by default
- 8 One privacy service at six enforcement points
- 9 Retrieval inside platforms already run, as a rebuildable, entitlement-filtered index
- 10 Git as the configuration of record for prompts, pins and policies
- 11 Capability separation as the first security control
- 12 Memory last, as a governed record class

What to select

138 products scored on eight criteria · 58 Strategic · 67 Tactical · 13 Experimental

Where the Strategic choices are

Products by tier, layer (L9→L1) and control (C1→C8)



A Strategic tier carries a condition

18 of the 58 apply only where a given cloud is primary, or where a platform is already operated. The condition is the decision.

What drives the tiers

Regulated-FS weights favour deployment flexibility and low lock-in, so open, self-hostable components take most Strategic slots. No commercial governance tool reached Strategic on public evidence.

The cloud-neutral core we would select today

Layer / control	Selection	Independent alternative or note
C1 gateway	LiteLLM Enterprise (hardened, pinned) or Kong AI Gateway	Cloud gateway where that cloud is primary
L9 evaluation	Langfuse or MLflow + firm OpenTelemetry collector	Two red-team tools, one vendor-independent
C3 privacy / C4 identity	Presidio behind a privacy API • workforce IdP + OPA + SPIFFE	Cloud DLP / Entra Agent ID per cloud
C5 configuration	Git as configuration of record; prompts as code	Vendor registries are caches only
L8 ingestion	Docling + Unstructured inside a built envelope	Specialist parsers for hard documents
L7 / L6 retrieval	Sentence Transformers + pgvector (or Elasticsearch where run)	Qdrant or Milvus after a failed load test
L4 tools	Read-only MCP tools behind a governed gateway	OpenAPI tools (MCP originated at Anthropic)
L3 orchestration	LangGraph on Temporal	Microsoft Agent Framework, ADK, Pydantic AI
L2 inference	Primary cloud's in-region model service + vLLM exit route	SGLang as backup engine once its CVE fix is confirmed
L1 models	Two vendors from OpenAI, Anthropic, Mistral, Gemini; Gemma 4 or Mistral self-hosted	For Claude: GPT-6.1 Sol, Gemini 3.8 Flash or Mistral Medium 3.5

Treat models as a portfolio, not a bet

Primary mid-tier

One vendor through the primary cloud's in-region model service

Second mid-tier

An unrelated vendor qualified on the same evaluation suite

Small model

Classification, routing and judging at low cost

Open-weight exit route

Gemma 4 or Mistral on vLLM: the stressed-exit drill

- Top tiers are gated and lifetimes are short: one Gemini Flash version lives about five months. Re-qualification is routine work, not an event.
- Chinese-origin families: decide the route, not the brand. Self-hosted weights by explicit policy or in-tenant hosting; never the vendor's own API for client data.
- Numbers are never generated by the model; they come from the attribution engine through read-only tools.

Keep, remove, add

Keep

The nine-layer spine as a teaching device ·
vLLM · LangGraph · Docling · pgvector, Qdrant,
Milvus, Elasticsearch · Langfuse, LangSmith ·
MCP and A2A behind a governed gateway ·
the portfolio model vendors

Remove or demote

Labels that do not exist (Gemma 2.9, QI4) ·
unverifiable tiles (EthicalAgents, Ragoos) ·
archived TGI · a router as 'the' access layer ·
memory as its own infrastructure layer ·
desktop runtimes in production

Add

AI traffic gateway · guardrails as policy ·
privacy service · agent identity and tool
governance · configuration of record · FinOps ·
AI security · governance and evidence store ·
durable execution · ingestion envelope

Deliberately not selected, on evidence

Avoid	Why
Archived or deprecated: TGI, OpenAI Agent Builder, AutoGen for new code, Helicone, Zep Community Edition	Archived, shut down, superseded or in maintenance mode
EthicalAgents, Ragoos	Could not be verified as real products
A third-party broker holding client tokens (Composio managed cloud)	Unresolved token-exposure incident, May 2026
Any Chinese-origin vendor's own API for client data	PRC storage and unremediated regulatory findings
Jina weights, MinerU above thresholds, a modified AGPL Firecrawl server	Licence blockers without a commercial licence
LM Studio as a service; training-on-data model tiers	Terms blockers
Billing intermediation through a gateway or router	Puts a vendor between the firm and its model contract

Not avoided but not yet: memory, autonomous agents with write tools, multi-agent delegation, fine-tuning, own-GPU fleets, dedicated vector databases without a failed load test.

The regulated firm's view

What supervisors will ask for, and the worked example that makes it concrete

What a supervisor or validator will ask to see

Model risk (SS1/23)

A GenAI model-risk standard, inventory entry, independent validation report, monitoring results, change records

EU AI Act

Use-case classification, AI literacy records, Article 26 logs (six months or more) and oversight assignments for any high-risk use

Third parties (PS7/26, DORA)

Provider assessments, notifications from 18 March 2027, register entries, tested exit plans including a stressed exit

Data

Processing-region evidence per call, transfer risk assessments, erasure runbooks covering vectors, caches and backups

Audit trail

Per-output evidence pack: prompt and model versions, data snapshot, tool calls, evaluation results, approver identity

Security (OWASP 2026)

Red-team results mapped to the LLM and Agentic Top 10 lists; supply-chain gate records

Worked example: the attribution-commentary agent

1 Analyst request

Identity and policy check (C4)

2 Workflow graph

Deterministic; one drafting step (L3)

3 Read-only data

Attribution engine via governed tools (L4)

4 House style

Retrieval of prior commentary (L8–L6)

5 Draft

Model via the gateway, in region (C1, L2, L1)

6 Evaluate

Every figure matches the engine (L9, C2)

7 Approve

Named portfolio manager (C4)

8 Evidence pack

Stored, immutable, reproducible (C8)

A multi-asset fund, Brinson-style attribution (allocation, selection, currency). Generic and illustrative: not any firm's platform.

What the agent must never do matters more than what it can do



Generate or alter a number

Every figure comes from the approved attribution output and is traceable



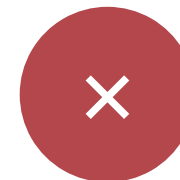
Present inference as data

Commentary distinguishes the engine's figures from the narrative



Publish without approval

Only a named, entitled person can resume the approval gate



Leave no record

Outputs are reproducible; evaluation evidence is retained

The control that catches the one failure that matters

A wrong number in a client commentary is caught by a deterministic numeric-faithfulness check: an evaluation scorer reused inline as a guardrail.

Delivery

Four reference stacks · build vs buy · lock-in · an 18-month roadmap

Four reference stacks: Stack A leads

A • Regulated enterprise

LEAD

Private deployment, governance and evidence before speed; tested exit for every material dependency

B • Cloud-native managed

The primary cloud's lead service in each category; firm-owned evidence and configuration keep exit possible

C • Open-source first

Open licence and self-hosted route for every component; the cloud as infrastructure, not platform

D • Minimal start-small

Stack A cut to one use case, with an explicit 'do not build yet' list

Same control-plane minimum in every stack

Gateway, evaluation harness, evidence store, privacy API, agent identity, Git configuration, budgets that fail closed. Stacks differ in who runs the components, not in whether they exist.

Build the control statement; buy the commodity

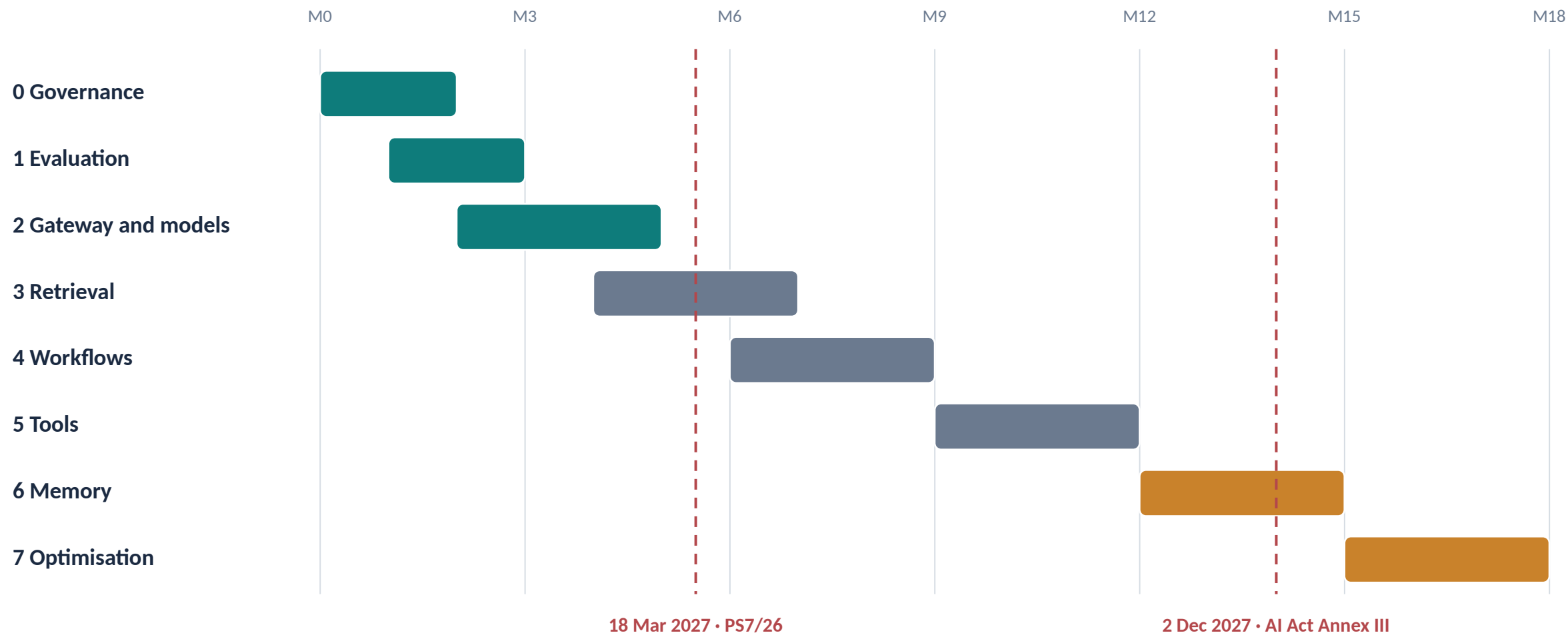
Component	Decision	What the firm owns
Gateway (C1), guardrails (C2), privacy (C3)	Hybrid	Routes, policies, test sets, keys; the product is replaceable
Identity (C4)	Buy the IdP, build the policy	Agent registration, policies in Git
Configuration (C5), FinOps (C6)	Build (thin)	Release manifest, evaluation gate, allocation rules
Governance (C8)	Build the store, buy the workflow	Evidence store and inventory outlive any tool
Evaluation (L9)	Hybrid	Datasets and scorers in Git; platform replaceable
Ingestion (L8)	Build the envelope	No product emits lineage; parsers adopted
Stores (L6)	Reuse what is run	Retrieval interface and rebuild pipeline
Models (L1)	Buy; adopt open weights	Portfolio policy, qualification suite, retirement calendar
Fine-tuning	Do not build yet	May turn a deployer into a provider under the AI Act

Which lock-in is acceptable, and which is not

Area	Acceptable	Unacceptable without an exit
Models (L1)	Open weights the firm holds	A single proprietary vendor for an important service
Orchestration (L3)	Open frameworks	Vendor-hosted agent state for regulated workflows
Tools (L4)	MCP and A2A as open specifications	Credential custody in a third party's multi-tenant cloud
Stores (L6)	A vector index rebuildable from source	Entitlement logic only in proprietary syntax
Evaluation (L9)	Production APM module	Datasets only in a vendor UI
Configuration (C5)	Pins in a manifest	Prompt text or change history only in a vendor registry
Governance (C8)	Policy packs, OpenLineage	An evidence store held only by a vendor

The pattern: own the data, the policy and the evidence; let the engines be bought and replaced.

An 18-month roadmap, governance first and memory last



October 2026 to March 2028. Phases overlap; each starts when its predecessor's exit criteria are in sight. The exit drill (model switched by configuration only) must pass before March 2027.

Why evaluation comes before the first model call

1

It is the validation evidence

Without a suite there is nothing for a validator to re-perform and nothing to approve

2

It is what makes exit possible

A replacement model is qualified only by running the same suite

3

Every later change is a model change

Model, prompt, embedding and tool changes all need a regression baseline

4

Evidence cannot be recreated

Free tiers keep traces for weeks; an unrecorded output has no reproducible record

Decisions for the leadership team

Adopt the reference architecture

Control plane first; Stack A as the target; the lock-in rules as design policy

Name the accountable owner

An SMF for GenAI model risk and a GenAI standard to SS1/23 quality

Fund Phases 0-2 now

Governance, evaluation harness, gateway and two-vendor model access, with the exit drill before 18 March 2027

Choose the first use case

The attribution commentary: clear boundaries, checkable numbers, a named approver

Own the control plane. Rent the components.

Full evidence: master document (Word/PDF), product technical appendix (138 scored products), offline explorer, dataset and source archive. Every claim is labelled and sourced. Researched and drafted with an Anthropic model; Anthropic items scored on the same rubric, with tiers set by the reader marked.